

Guía Metodológica de la Encuesta de Madurez CMMC / NIS2 / ENS

Versión: 1.0

Propósito: Orientar el diseño, la aplicación, el análisis y la interpretación de la Encuesta Integral de Madurez CMMC / NIS2 / ENS.

1. Objetivos de la encuesta

La encuesta persigue varios objetivos simultáneos y no necesariamente modestos:

1. Medir la madurez de ciberseguridad de organizaciones españolas usando como referencia conceptual CMMC 2.0 (Niveles 1–3) y los controles de NIST SP 800-171/172, alineados con ENS, NIS2 y DORA.
2. Generar indicadores comparables entre organizaciones, sectores y tamaños, que puedan evolucionar en una suerte de “SPRS-nacional” o índice de madurez sectorial.
3. Proporcionar insumos cuantitativos para modelos de riesgo y cálculo de retorno de la inversión (ROI) en ciberseguridad, facilitando el diálogo entre CISOs, CFOs, actuarios y otros seres racionales.
4. Fomentar una cultura de mejora continua, evitando tanto el derrotismo apocalíptico como el triunfalismo vacío: la intención es propositiva, no inquisitorial.

2. Alcance y población objetivo

- **Ámbito geográfico:** España (organizaciones establecidas en territorio español, con o sin actividad internacional).
- **Sectores:** Administración pública, sanidad, energía, industria, transporte, financiero, TIC, defensa, educación e I+D, y otros sectores con dependencia digital significativa.
- **Tamaño:** Desde pymes hasta grandes grupos, con segmentación por tramos de empleados.
- **Perfil de respondentes:**
 - Responsables de ciberseguridad (CISO, RSSI, etc.).
 - Responsables de TI o seguridad tecnológica.
 - Responsables de cumplimiento normativo / riesgo operativo.
 - En organizaciones pequeñas, el “responsable tácito” (normalmente IT manager, CEO o similar).

3. Diseño del cuestionario

El cuestionario se estructura en **12 bloques temáticos**, alineados con:

- Las 14 familias de NIST SP 800-171,
- Los niveles de madurez de CMMC 2.0,
- Los principios de NIS2, ENS y DORA,
- Y las obsesiones legítimas de cualquier CISO que haya dormido poco.

Los bloques son:

5. Gobernanza, estrategia y cultura.
6. Marcos de referencia (CMMC, NIST, ENS, NIS2, etc.).
7. Gestión de activos, configuración y vulnerabilidades.
8. Control de acceso e identidad.
9. Protección de información sensible.
10. Monitorización, detección y respuesta a incidentes.
11. Formación, concienciación y cultura.
12. Proveedores y cadena de suministro.
13. Documentación, evidencias y auditabilidad.
14. Métricas, indicadores e índices compuestos.
15. Inversión, ROI y mejora continua.
16. Percepción global y ambición.

3.1. Formato de respuestas

Se han utilizado principalmente:

- Escalas ordinales (por ejemplo, de 0 a 5 en madurez, de 0–20 % a 96–100 % en cobertura).
- Opciones múltiples para capturar estados de implementación (inexistente, parcial, completo, avanzado).
- Respuestas múltiples seleccionables donde sea útil identificar varias prácticas simultáneas.
- Campo abierto de comentarios para matices cualitativos.

Este formato facilita el cálculo de indicadores cuantitativos y la construcción de índices de madurez, sin renunciar a la riqueza narrativa cuando sea necesaria.

4. Mapeo metodológico a CMMC / NIST / ENS / NIS2

Cada pregunta del cuestionario se vincula a:

- Uno o varios controles de NIST SP 800-171/172 (por ejemplo, AC-2, CM-6, IR-2).
- La familia correspondiente en el modelo CMMC (Control de Acceso, Gestión de Configuración, Respuesta a Incidentes, etc.).
- Requisitos relevantes de ENS (medidas de seguridad organizativas, operativas y de protección).
- Disposiciones de NIS2, en particular las relacionadas con gestión de riesgos, medidas técnicas y organizativas, y notificación de incidentes.
- Disposiciones sectoriales como DORA (en el ámbito financiero), cuando proceda.

El detalle completo de este mapeo se recoge en el documento “Mapeo Detallado Pregunta ↔ Requisito Normativo”.

5. Sistema de puntuación y cálculo de índices

5.1. Puntuación de cada ítem

Para cada pregunta cerrada se propone:

- Asignar una puntuación numérica a cada opción de respuesta, en una escala interna (por ejemplo, de 0 a 4 o de 0 a 5).
- Asegurar que la escala respeta el orden lógico de madurez (0 = inexistente, máximo = práctica avanzada y sostenida).
- En el caso de respuestas basadas en porcentajes, usar rangos que reflejen hitos relevantes (ej. 0–20 %, 21–50 %, etc.), con progresión casi geométrica hacia los niveles superiores.

Ejemplo simplificado:

- 0–20 % → 0 puntos.
- 21–50 % → 1 punto.
- 51–80 % → 2 puntos.
- 81–95 % → 3 puntos.
- 96–100 % → 4 puntos.

5.2. Ponderación por bloques

No todos los bloques tienen el mismo impacto en la postura de seguridad global. Se sugiere:

- Asignar pesos por bloque (ej. 10–15 % para gobernanza, 15–20 % para control de acceso y monitorización, etc.).
- Ajustar estos pesos según el sector (por ejemplo, mayor peso de resiliencia operativa en sectores críticos, mayor peso de protección de datos en sanidad).

5.3. Índice Global de Madurez (IGM)

El **Índice Global de Madurez (IGM)** se calcula como:

$$[\text{IGM} = \sum_{i=1}^n (P_i \times W_i)]$$

donde:

- (P_i) es la puntuación normalizada (0–1) del bloque (i).
- (W_i) es el peso del bloque (i), con ($\sum W_i = 1$).

El resultado se puede escalar a 0–100 para facilitar su interpretación.

5.4. Índices parciales

Se recomienda calcular:

- Índice de Gobernanza y Cultura (IGC).
- Índice Técnico (ITEC) (controles técnicos propiamente dichos).
- Índice de Resiliencia (IRES) (resiliencia operacional, respuesta a incidentes, continuidad).
- Índice de Cadena de Suministro (ICAS).

Esto permite identificar “musculaturas” y “esguinces” específicos.

6. Cálculo del ROI y uso de la plantilla Excel

La plantilla Excel asociada permite:

17. Relacionar la evolución del IGM con la evolución de incidentes, pérdidas evitadas, interrupciones de servicio y otros indicadores de impacto.
18. Cuantificar el beneficio económico estimado (reducción de pérdidas esperadas, mejora en la probabilidad de ganar/retener contratos, reducción de primas de ciberseguro, etc.).
19. Calcular métricas de ROI tales como:

$$\left[\text{ROI} = \frac{\text{Beneficios estimados} - \text{Coste de inversión}}{\text{Coste de inversión}} \right]$$

La guía sugiere utilizar, siempre que sea posible:

- Estimaciones basadas en datos históricos propios (frecuencia y severidad de incidentes).
- Datos sectoriales (por ejemplo, informes nacionales de incidentes gestionados por INCIBE).
- Modelos actuariales simples (pérdida esperada = probabilidad × impacto).

7. Procedimiento de aplicación de la encuesta

7.1. Preparación

- Definir claramente el alcance organizativo (empresa, grupo, unidad de negocio).
- Identificar a las personas clave que deben responder (IT, seguridad, riesgo, negocio).
- Explicar el propósito: no se trata de buscar culpables, sino de establecer una línea base y oportunidades de mejora.

7.2. Recogida de respuestas

- Preferiblemente mediante una plataforma en línea, que permita exportar datos a CSV/Excel.
- Garantizar la confidencialidad a nivel de organización en los análisis agregados.
- Establecer un plazo razonable de respuesta (2–4 semanas) y recordatorios amigables.

7.3. Validación y contraste

- Revisar respuestas incoherentes o extremos sospechosos (por ejemplo, autopercepción 5/5 con ausencia total de evidencias).
- Permitir una breve entrevista de contraste con el responsable de ciberseguridad para resolver dudas.
- Documentar las decisiones de ajuste (sin entrar en inquisición).

8. Interpretación de resultados

8.1. Niveles de madurez sugeridos

A partir del IGM (0–100), se propone:

- 0–20: Inmadurez crítica (modo “supervivencia”).
- 21–40: Básico/Reactivo.
- 41–60: Intermedio, con capacidades razonables pero heterogéneas.
- 61–80: Avanzado (equivalente a un CMMC Nivel 2 sólido).
- 81–100: Referente (cercano a un Nivel 3 en ámbitos críticos).

8.2. Comparaciones sectoriales y entre tamaños

- Evitar comparaciones simplistas (“mejor/peor”), centrándose en el contexto sectorial y la criticidad.
- Utilizar cuartiles para ubicar a cada organización en su sector y tamaño.
- Señalar especialmente las áreas donde el gap entre ambición declarada y madurez real es más evidente.

9. Uso de los resultados para la mejora

Los resultados deben usarse para:

- Priorizar iniciativas de mejora con criterios de riesgo y ROI.
- Dimensionar de forma más racional la inversión en ciberseguridad.
- Justificar ante órganos de gobierno y auditores las decisiones tomadas.
- Alimentar una hoja de ruta alineada con CMMC/NIST/ENS/NIS2, evitando tanto la parálisis por análisis como la improvisación alegre.

10. Advertencias, limitaciones y virtudes

- Es una autoevaluación estructurada, no una auditoría forense.
- Depende de la honestidad y conocimiento de los respondentes; de ahí la importancia del contraste posterior.
- No sustituye ningún esquema de certificación, pero puede prepararlos y hacerlos menos traumáticos.
- Bien utilizada, puede convertirse en un instrumento de diálogo entre tecnología, negocio, regulación y finanzas, que es donde suceden los milagros (y los presupuestos).

Fin de la Guía Metodológica.

Si después de leerla sigues queriendo aplicar la encuesta, eres claramente parte de la solución.